API Contract: RAG-Diary

> สัญญาของปลายทาง API ทุกเส้น ประกอบด้วยวิธีร้องขอ รูปแบบคำตอบ รหัสข้อผิดพลาด และข้อกำหนดการยืนยันตัวตน เพื่อให้ทีมพัฒนาและทดสอบเข้าใจตรงกัน

1. Document Control

หัวข้อ	รายละเอียด
ชื่อเอกสาร	API Contract
เวอร์ชัน	1.0
วันที่จัดทำ	15 ตุลาคม 2569
ผู้จัดทำ	Business Analyst / System Analyst (เจ้าของผลงาน)
สถานะ	ผ่านการตรวจทานรอบ 1 (25 ตุลาคม 2569)
เอกสารที่เกี่ยวข้อง	DATA-MODEL, SEQUENCE-DIAGRAMS, SRS

2. Purpose และ Scope

เอกสารนี้ตอบคำถามว่า "แต่ละปลายทาง API รับข้อมูลอะไร คืนอะไร และผิดพลาดได้อย่างไร" เพื่อใช้เป็นข้อตกลงร่วมระหว่างทีมหน้าและทีมหลัง

ขอบเขต: ปลายทางทั้งหมด 15 เส้น ครอบคลุมการยืนยันตัวตน การจัดการบันทึก และการประมวลผลด้วย AI นอกขอบเขต: โครงสร้างข้อมูลเชิงลึก (อยู่ใน DATA-MODEL) และลำดับการเรียก (อยู่ใน SEQUENCE-DIAGRAMS)

3. ธรรมเนียมของ API

หัวข้อ	ค่า
Base URL	ฝั่งหน้าจอเรียกผ่าน origin ของตัวเองที่ /api แล้ว Next.js proxy ไปยังเซิร์ฟเวอร์ Elysia (ตั้งเป้าหมายที่ API_PROXY_TARGET)
รูปแบบข้อมูล	JSON ยกเว้น POST /chat ที่ตอบเป็นข้อความแบบ stream
การยืนยันตัวตน	cookie แบบ httpOnly สองตัว (rag_access, rag_refresh) ที่เซิร์ฟเวอร์ตั้งให้เอง ยังรับหัวข้อ Authorization เป็น Bearer token ได้เพื่อความเข้ากันได้กับสคริปต์
รูปแบบข้อผิดพลาด	{"error": "ข้อความอธิบาย"}
การบังคับ auth	ปลายทางกลุ่ม notes และ ai บังคับผ่าน authGuard ทุกเส้น

ตัวแปรสภาพแวดล้อมที่ต้องใช้ ฝั่งเซิร์ฟเวอร์ได้แก่ SUPABASE_URL, SUPABASE_ANON_KEY และ GEMINI_API_KEY ฝั่งหน้าจอได้แก่ API_PROXY_TARGET ซึ่งใช้ตอน build เพื่อกำหนดว่า /api/* จะถูก proxy ไปที่ใด (โค้ดใช้ anon key เพื่อให้ RLS มีผลเสมอ และใช้ service role key เป็นทางถอยเท่านั้น เพราะจะข้าม RLS จึงไม่แนะนำให้ใช้เป็นค่าหลัก)

4. ตารางสรุปปลายทาง

#	Method	Path	ยืนยันตัวตน	คำอธิบาย	ความต้องการ
1	POST	/auth/register	ไม่ต้อง	ลงทะเบียนบัญชีใหม่	FR-01
2	POST	/auth/login	ไม่ต้อง	เข้าสู่ระบบ	FR-02
3	POST	/auth/logout	ไม่ต้อง	ออกจากระบบ	FR-03
4	GET	/auth/me	ต้อง	ตรวจสอบผู้ใช้ปัจจุบัน	FR-02, FR-03
5	GET	/notes	ต้อง	ดูบันทึกของผู้ใช้	FR-06
6	POST	/notes	ต้อง	สร้างบันทึกพร้อมดัชนี	FR-04, FR-05
7	PATCH	/notes/:id	ต้อง	แก้ไขบันทึก	FR-07
8	DELETE	/notes/:id	ต้อง	ลบบันทึกเดี่ยว	FR-08
9	POST	/search/semantic	ต้อง	ค้นหาเชิงความหมาย	FR-09
10	POST	/chat	ต้อง	ถามตอบกับบันทึก (stream)	FR-10
11	POST	/ai/summarize	ต้อง	สรุปอารมณ์และ prompt ภาพ	FR-11
12	POST	/ai/imagine	ต้อง	สร้างภาพจาก prompt	FR-12
13	POST	/auth/refresh	ไม่ต้อง (ใช้ refresh token)	ต่ออายุ access token	FR-02, FR-03
14	GET	/export	ต้อง	ส่งออกบันทึกทั้งหมดเป็น JSON	FR-13
15	DELETE	/data	ต้อง	ลบบันทึกทั้งหมดของผู้ใช้	FR-14

5. รายละเอียดปลายทาง

5.1 POST /auth/register

ลงทะเบียนบัญชีใหม่ ไม่ต้องยืนยันตัวตน

Request

```
{ "email": "user@example.com", "password": "secret123" }
```

Response 200

```
{
  "user": { "id": "uuid", "email": "user@example.com" },
  "needsEmailConfirmation": false
}
```

พร้อมตั้ง cookie rag_access และ rag_refresh แบบ httpOnly, SameSite=Lax, Secure บน production โดยไม่ส่ง token ใด ๆ ใน body

ข้อผิดพลาด: 400 เมื่ออีเมลไม่ถูกต้องหรือรหัสผ่านสั้นกว่า 6 ตัวอักษร

5.2 POST /auth/login

เข้าสู่ระบบ ไม่ต้องยืนยันตัวตน

Request

```
{ "email": "user@example.com", "password": "secret123" }
```

Response 200

```
{
  "user": { "id": "uuid", "email": "user@example.com" }
}
```

พร้อมตั้ง cookie rag_access และ rag_refresh แบบ httpOnly โดยไม่ส่ง token ใน body

ข้อผิดพลาด: 401 เมื่อข้อมูลเข้าสู่ระบบไม่ถูกต้อง

5.3 POST /auth/logout

ออกจากระบบ เซิร์ฟเวอร์ล้าง cookie ทั้งสองตัว (token เป็นแบบไม่เก็บสถานะ จึงไม่มีการเรียกกลับไปยังผู้ให้บริการยืนยันตัวตน)

Response 200

```
{ "success": true }
```

5.4 GET /auth/me

ตรวจสอบผู้ใช้ปัจจุบัน ต้องยืนยันตัวตน

Response 200

```
{ "user": { "id": "uuid", "email": "user@example.com" } }
```

ข้อผิดพลาด: 401 เมื่อไม่มี cookie หรือ token ใช้ไม่ได้

5.5 GET /notes

ดูบันทึกทั้งหมดของผู้ใช้ เรียงจากใหม่ไปเก่า ต้องยืนยันตัวตน

Response 200

```
[
  {
    "id": "uuid",
    "content": "เนื้อหาบันทึก",
    "tag": "General",
    "created_at": "2026-10-15T10:00:00Z"
  }
]
```

คืนเฉพาะคอลัมน์ที่หน้าจอต้องใช้ ไม่ส่ง embedding และ user_id กลับ (ปิดข้อสังเกต R-08)

5.6 POST /notes

สร้างบันทึกใหม่ พร้อมสร้างดัชนีความหมายโดยอัตโนมัติ ต้องยืนยันตัวตน

Request

```
{ "content": "เนื้อหาบันทึก", "tag": "Work" }
```

ค่า tag ไม่บังคับ หากไม่ส่งระบบจะตั้งค่าเริ่มต้นเป็น General เนื้อหาจำกัด 20,000 ตัวอักษร และแท็กไม่เกิน 50 ตัวอักษร ถ้าสร้าง embedding ไม่สำเร็จ ระบบยังบันทึกเนื้อหาไว้และปล่อย embedding ว่าง (บันทึกนั้นจะยังไม่ปรากฏในผลค้นจนกว่าจะบันทึกซ้ำ)

Response 200 คืนแถวบันทึกที่สร้างแล้ว

ข้อผิดพลาด: 401 เมื่อไม่ผ่านการยืนยันตัวตน

5.7 PATCH /notes/:id

แก้ไขบันทึก พร้อมสร้างดัชนีความหมายใหม่ ต้องยืนยันตัวตน

Request

```
{ "content": "เนื้อหาที่แก้ไข", "tag": "Work" }
```

Response 200

```
{ "success": true }
```

ข้อผิดพลาด: 401 เมื่อไม่ผ่านการยืนยันตัวตน

5.8 DELETE /notes/:id

ลบบันทึกเดี่ยวตามรหัส ต้องยืนยันตัวตน

Response 200

```
{ "success": true }
```

ข้อผิดพลาด: 401 เมื่อไม่ผ่านการยืนยันตัวตน และ 404 เมื่อไม่พบบันทึกหรือบันทึกนั้นไม่ใช่ของผู้ใช้

5.9 POST /search/semantic

ค้นหาเชิงความหมาย ต้องยืนยันตัวตน

Request

```
{ "query": "ความรู้สึกช่วงนี้", "threshold": 0.6, "limit": 10 }
```

ค่า threshold และ limit ไม่บังคับ ค่าเริ่มต้นคือ 0.6 และ 10 ตามลำดับ คำค้นยาว 1 ถึง 500 ตัวอักษร และ limit อยู่ระหว่าง 1 ถึง 50

Response 200 คืนรายการบันทึกที่คล้ายพร้อมคะแนนความคล้าย

ข้อผิดพลาด: 401 เมื่อไม่ผ่านการยืนยันตัวตน ส่วนข้อผิดพลาดจากผู้ให้บริการภายนอกจะถูกบันทึกใน log ฝั่งเซิร์ฟเวอร์ และฝั่งผู้ใช้ได้รับ 500 พร้อมข้อความทั่วไป

5.10 POST /chat

ถามตอบกับบันทึกของผู้ใช้ ต้องยืนยันตัวตน

Request

```
{ "query": "สัปดาห์นี้ฉันรู้สึกอย่างไร" }
```

Response 200 เป็นข้อความแบบ stream ไม่ใช่ JSON ฝั่งหน้าจอต้องอ่านแบบ stream

ข้อผิดพลาด: 401 เมื่อไม่ผ่านการยืนยันตัวตน ส่วนข้อผิดพลาดจากผู้ให้บริการภายนอกจะถูกบันทึกใน log ฝั่งเซิร์ฟเวอร์ และฝั่งผู้ใช้ได้รับ 500 พร้อมข้อความทั่วไป

5.11 POST /ai/summarize

สรุปอารมณ์ของบันทึกและเสนอ prompt ภาพ ต้องยืนยันตัวตน

Request

```
{ "notes": [ { "created_at": "2026-10-15T10:00:00Z", "content": "เนื้อหา" } ] }
```

ระบบตรวจโครงสร้าง notes แล้ว (created_at ไม่บังคับ, content 1 ถึง 20,000 ตัวอักษร, ไม่เกิน 200 รายการ) และตอบ 400 เมื่อ notes ว่าง (ปิดข้อสังเกต R-03)

Response 200

```
{ "result": "ข้อความสรุป ...\nIMAGE_PROMPT: ..." }
```

5.12 POST /ai/imagine

สร้างภาพจาก prompt ต้องยืนยันตัวตน prompt ยาว 1 ถึง 1,000 ตัวอักษร

Request

```
{ "prompt": "a calm sunrise over a paper notebook" }
```

Response 200

```
{ "imageUrl": "https://..." }
```

5.13 POST /auth/refresh

ต่ออายุ session โดยอ่าน refresh token จาก cookie rag_refresh แล้วตั้ง cookie ชุดใหม่ ไม่ต้องเข้าสู่ระบบใหม่

Request (ไม่ต้องมี body เมื่อเรียกจากเบราว์เซอร์)

```
{ "refresh_token": "..." }
```

body ใช้เฉพาะไคลเอนต์ที่ไม่ใช่เบราว์เซอร์ ส่วนเบราว์เซอร์ส่ง cookie อัตโนมัติ

Response 200

```
{
  "user": { "id": "uuid", "email": "user@example.com" }
}
```

พร้อมตั้ง cookie ชุดใหม่ทั้งสองตัว (rotate) และไม่ส่ง token ใน body

ข้อผิดพลาด: 401 เมื่อ refresh token ไม่ถูกต้องหรือหมดอายุ พร้อมล้าง cookie ทั้งสองตัว ฝั่งหน้าจอจึงพาผู้ใช้ไปหน้าเข้าสู่ระบบ

5.14 GET /export

ส่งออกบันทึกทั้งหมดของผู้ใช้ที่ล็อกอินเป็น JSON ต้องยืนยันตัวตน

Response 200

```
{
  "exported_at": "2026-11-05T00:00:00.000Z",
  "count": 12,
  "entries": [
    { "id": "uuid", "content": "...", "tag": "General", "created_at": "..." }
  ]
}
```

5.15 DELETE /data

ลบบันทึกทั้งหมดของผู้ใช้ที่ล็อกอินในคำสั่งเดียว ต้องยืนยันตัวตน

Response 200

```
{ "success": true, "deleted": 12 }
```

ข้อผิดพลาด: 401 เมื่อไม่ได้ยืนยันตัวตน

6. รหัสข้อผิดพลาดที่ใช้

รหัส	ความหมาย	ตัวอย่างสถานการณ์
200	สำเร็จ	คำขอทำงานครบ
400	ข้อมูลไม่ถูกต้อง	อีเมลหรือรหัสผ่านไม่ผ่านรูปแบบ
401	ไม่ได้ยืนยันตัวตน	ไม่มี cookie หรือ token ใช้ไม่ได้
403	แหล่งที่มาไม่ได้รับอนุญาต	Origin ของคำขอไม่อยู่ในรายการที่อนุญาต (กัน CSRF)
404	ไม่พบข้อมูล	ไม่พบบันทึก หรือบันทึกนั้นไม่ใช่ของผู้ใช้
429	เรียกถี่เกินกำหนด	เกินลิมิตต่อผู้ใช้ (เช่น chat 20 ครั้งต่อนาที)
500	ข้อผิดพลาดภายใน	ข้อผิดพลาดที่ไม่คาดคิด รวมถึงกรณีผู้ให้บริการ AI ล้มเหลว (ข้อเสนอ: แยกเป็น 502 เพื่อให้ฝั่งหน้าจอแยกสาเหตุได้)
503	บริการ AI ภายนอกไม่พร้อม	ผู้ให้บริการสร้างภาพตอบ 429 เพราะโควตาของแผนไม่พอ

ลิมิตต่อผู้ใช้ (ต่อนาที): search 60, chat 20, summarize 20, imagine 5, notes 60 ใช้การนับแบบ fixed window และคืน 429 เมื่อเกิน

7. ข้อสังเกตและข้อเสนอ

ประเด็น	รายละเอียด	ข้อเสนอ
POST /chat เป็น stream	ตอบเป็นข้อความแบบ stream ไม่ใช่ JSON	ควรระบุสัญญาสตรีมให้ชัดในเอกสารและการทดสอบ

ประเด็น	รายละเอียด	ข้อเสนอ
POST /ai/summarize ไม่ตรวจชนิด	แก้แล้ว: ตรวจสคีมาของ notes และปฏิเสธเมื่อว่าง	ปิดข้อสังเกตนี้แล้ว (R-03)
การจำกัดอัตราการเรียก	ทำในโค้ดแล้ว (search 60, chat 20, summarize 20, imagine 5, notes 60 ต่อนาที)	รอเปิดใช้หลังรัน migration (R-02)
GET /notes คืนทุกคอลัมน์	แก้แล้ว: คืนเฉพาะ id, content, tag, created_at	ปิดข้อสังเกตนี้แล้ว (R-08)

8. References

เอกสาร	ความสัมพันธ์
DATA-MODEL	โครงสร้างข้อมูลที่ปลายทางอ่านและเขียน
SEQUENCE-DIAGRAMS	ลำดับการเรียกปลายทางเหล่านี้
SRS	ความต้องการที่ปลายทางรองรับ
TRACEABILITY-MATRIX	การผูกปลายทางกับความต้องการ